

RideWheelShare — Hosting Security Configuration Assessment

cPanel / WHM Reseller scope analysis · Hosting tier: Reseller 60 · Prepared: 2026-08-05 · For: RideWheelShare Operations Team

Purpose of this report: This document records what security hardening controls are achievable within the Reseller 60 cPanel/WHM tier at hosting.com, what requires per-site `.htaccess` configuration, and what requires escalation to hosting.com's infrastructure team. Items are numbered to match the original security questionnaire.

Hosting provider	hosting.com
Reseller tier	Reseller 60
Control panel	cPanel / WHM
Web server	Apache (mod_headers available per account)
Assessment date	2026-08-05

Summary table

#	Security control	Reseller scope	Mechanism
1	HSTS (HTTP Strict Transport Security)	Per-site only	<code>.htaccess</code> / cPanel Apache config per account
2	CSP, X-Frame-Options, X-Content-Type-Options	Possible per site	<code>.htaccess</code> Header always set directives
3	Referrer-Policy	Possible per site	<code>.htaccess</code> Header always set directive
4	SQLi / XSS prevention & WAF (ModSecurity)	Partially within scope	Code-level (developer); ModSecurity toggle via WHM
5	Authentication & access control (MFA, IP restriction)	Partially within scope	WHM 2FA + password policy; IP restriction needs hosting.com for VPN/server-wide

1. HSTS (HTTP Strict Transport Security) Per-site only

HSTS headers **can** be implemented per individual cPanel account (i.e., per hosted website) via `.htaccess` or Apache configuration within cPanel.

Limitation: The reseller *cannot* apply HSTS at the server/WHM level — that requires root/server admin access, which hosting.com retains. Each end-client would need to configure it themselves, or the reseller can do it per account via cPanel's "Apache Configuration" tools or `.htaccess`.

Implementation (per site `.htaccess`):

```
# Enable HSTS for 1 year; include subdomains
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"
```

Prerequisites: The site must already be served exclusively over HTTPS before enabling HSTS. Applying HSTS on an HTTP-only or mixed site will lock users out.

2. Security headers: CSP, X-Frame-Options, X-Content-Type-Options Possible per site

All three headers can be added via `.htaccess` rules within each individual cPanel account. This is within the reseller's power to configure for their own or their clients' sites.

Limitation: Cannot be enforced globally across all accounts from WHM; must be done per-site unless a server-level config change is requested from hosting.com support.

Implementation (per site `.htaccess`):

```
Header always set X-Frame-Options "SAMEORIGIN"
Header always set X-Content-Type-Options "nosniff"
Header always set Content-Security-Policy "default-src 'self'"
```

Header notes

Header	Recommended value	Purpose
X-Frame-Options	SAMEORIGIN	Prevents clickjacking by blocking the site from being loaded in an <code><iframe></code> on a different origin.
X-Content-Type-Options	nosniff	Stops browsers from MIME-sniffing a response away from the declared content-type.
Content-Security-Policy	default-src 'self' (tighten per app)	Controls which origins may load scripts, styles, images, etc. The default-src 'self' value is a starting baseline; adjust to permit CDN assets, inline scripts, etc. as required by the application.

3. Referrer-Policy Possible per site

The `Referrer-Policy` header can be set per site via `.htaccess`. This is possible at the individual cPanel account/site level. It is *not* enforceable globally from WHM without server-level access.

Implementation (per site `.htaccess`):

```
Header always set Referrer-Policy "strict-origin-when-cross-origin"
```

Policy value	Behaviour
strict-origin-when-cross-origin	Sends full URL as referrer for same-origin requests; sends only the origin for cross-origin HTTPS → HTTPS; sends nothing for HTTPS → HTTP. Recommended default.
no-referrer	Never sends a referrer header. Maximum privacy; may break analytics.
same-origin	Sends referrer only for same-origin requests.

4. SQLi / XSS prevention & WAF Partially within scope

4.1 Parameterized queries / ORM (SQLi prevention)

This is a **code-level responsibility** of the website/application developer. The reseller has no mechanism to enforce parameterized queries or ORM usage from WHM or cPanel. This must be addressed in application code

(Laravel Eloquent, query builder bindings, prepared statements, etc.).

4.2 Input sanitizing / escaping (XSS prevention)

Also **code-level**, done within the application itself (WordPress plugins, custom PHP, framework template escaping, etc.). The reseller cannot enforce this from the hosting layer.

4.3 WAF — ModSecurity

cPanel includes **ModSecurity** (a Web Application Firewall) which can be enabled or configured per account in WHM.

Limitation: Rule management at the server level (e.g., OWASP CRS ruleset updates, custom server-wide rules) is controlled by hosting.com. The reseller can *toggle ModSecurity on/off per account* in WHM but *cannot add custom server-wide rulesets* without hosting.com involvement.

Action	Who can do it
Enable / disable ModSecurity per cPanel account	Reseller (WHM)
Add / update server-wide ModSecurity rulesets	hosting.com root only
Add per-site SecRule overrides via .htaccess	Possible if AllowOverride permits; confirm with hosting.com
Implement parameterized queries / input escaping	Application developer only

5. Authentication & Access Control

Partially within scope

5.1 Strong password policies for admin panels

The reseller **can** enforce password strength requirements for cPanel accounts via **WHM › Password Strength Configuration**. This sets a minimum complexity score that end-users must meet when changing their cPanel passwords.

5.2 Multi-factor authentication (MFA / 2FA)

cPanel supports **two-factor authentication (2FA)** for both WHM and individual cPanel logins. The reseller can enable and enforce this via WHM. Steps:

1. Log in to WHM.
2. Navigate to **Security Center › Two-Factor Authentication**.
3. Enable 2FA enforcement for all cPanel accounts under the reseller.
4. Each user then registers a TOTP authenticator app (Google Authenticator, Authy, etc.).

5.3 Restricting admin endpoints by IP / VPN

The reseller can use **WHM › Host Access Control** (TCP Wrappers) to restrict WHM/cPanel access by IP address for their own admin panel.

Limitation: Applying VPN-level restrictions or server-wide IP whitelisting requires coordination with hosting.com's infrastructure team; it is *not self-serve* at the Reseller 60 tier. The reseller must open a support ticket with hosting.com to request server-level firewall rules (e.g., `iptables` / `firewalld` rules that restrict port 2083/2087 to specific IP ranges).

Control	Reseller can self-serve?	Path
---------	--------------------------	------

Password strength policy	Yes	WHM › Password Strength Configuration
2FA for WHM & cPanel	Yes	WHM › Security Center › Two-Factor Authentication
IP restriction for WHM/cPanel	Partial	WHM › Host Access Control (per-service TCP wrappers)
VPN-level / server firewall IP whitelisting	No — requires hosting.com	Submit support ticket to hosting.com infrastructure team

Consolidated .htaccess template

The following block can be placed in the `public_html/.htaccess` of any cPanel-hosted site to apply items 1–3 in one step. Adjust the CSP policy for each application's asset requirements before deploying.

```
# -----
# Security headers – RideWheelShare baseline
# Apply per-site in public_html/.htaccess
# -----
<IfModule mod_headers.c>
  # 1. HSTS – requires site to be HTTPS-only first
  Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"

  # 2a. Clickjacking protection
  Header always set X-Frame-Options "SAMEORIGIN"

  # 2b. MIME-type sniffing protection
  Header always set X-Content-Type-Options "nosniff"

  # 2c. Content Security Policy – tighten for your app
  Header always set Content-Security-Policy "default-src 'self'"

  # 3. Referrer leakage control
  Header always set Referrer-Policy "strict-origin-when-cross-origin"
</IfModule>
```

Before deploying:

- Verify `mod_headers` is enabled on the account (it is on by default in most cPanel stacks; hosting.com can confirm).
- Test the CSP value in report-only mode (`Content-Security-Policy-Report-Only`) before switching to enforcement to avoid breaking legitimate assets (CDN scripts, fonts, inline styles).
- Do *not* set `Strict-Transport-Security` until the site has a valid TLS certificate and all HTTP traffic is redirected to HTTPS.

Escalation checklist for hosting.com

Items below cannot be self-served at Reseller 60 tier and require a support ticket or account upgrade:

- Server-wide ModSecurity ruleset management (OWASP CRS updates, custom global rules).
- Server-level firewall rules to restrict WHM/cPanel ports to specific IP ranges or VPN egress addresses.
- Global HSTS enforcement at the web server configuration layer (outside `.htaccess`).
- Global HTTP → HTTPS redirect at the virtual host / server config level.